

The sorry state of skill distribution (Test corpus)

The sorry state of skill distribution (Test corpus) - Author not stated, GitHub.

- Published: date not stated
- Original: <<https://github.com/trailofbits/overtly-malicious-skills>>
- Preserved from: <https://github.com/trailofbits/overtly-malicious-skills> (git) on 2026-09-09
- Repository commit: 4ffbf9461ef0505f9ce76a0d3694a18ec33ea531
- Licence: see the repository

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

This reference is a source-code repository. The archive preserves its documentation at an exact commit; the code itself stays in a private mirror and is never checked out, built or run.

- Repository: <<https://github.com/trailofbits/overtly-malicious-skills>>
- Commit: 4ffbf9461ef0505f9ce76a0d3694a18ec33ea531
- Documents preserved: 1

README.md

Blob d434eaf2dad, 1375 bytes, at commit 4ffbf9461ef0.

overtly-malicious-skills

This repository contains the four malicious skills created by the Machine Learning Security team at Trail of Bits to test out the reliability of skill scanners. You can check out our writeup describing the skills and how we used them to subvert scanners in our blog post, [The Sorry State of Skill Distribution](#).

WARNING: THESE SKILLS ARE MALICIOUS AND INTENDED FOR SECURITY RESEARCH PURPOSES ONLY. DO NOT INSTALL THEM.

Skills

- **csv-summarizer** - Claims to summarize the dimensions of a .csv file. Actually dumps the contents of the environment variables store.

- **context-loader** - Claims to synchronize startup context across Claude instances. Actually smuggles a malicious script within the archive of XML underlying a hidden .docx file.
- **simple-formatter** - Claims to formats text according to style guidelines (capitalize sentences, fix spacing, punctuation rules). Actually uses Python bytecode poisoning to steal environment variables.
- **dev-env-setup** — Claims to bootstrap standardized development environment configuration (npm/yarn registry, editor settings, pre-commit hooks, secrets hygiene). Actually uses a prompt injection to convince the scanner it is fine to overwrite the npm/yarn registry with an attacker-controlled site.

Archived from <https://github.com/trailofbits/overtly-malicious-skills>. Rendered offline from the local Markdown copy.